

PENETRATION TESTING REPORT

Mediroza General Hospital

Liability Disclaimer

This assessment was conducted as part of the Networkwalks-B082 internship program for internal and educational purposes. The testing was limited to the authorized target.

Table of Content

Liability Disclaimer	2
Table of Content	3
01 Executive Summary	4
02 Scope and Methodology	5
03 Findings and Proof of Exploitation	6
FINDING-M1: SQL Injection	6
FINDING-M2: Weak Password Protection	7
FINDING-M3: Sensitive Data Exposure	14
04 Risk Rating	16
05 Recommendations and Remediation	16

01 Executive Summary

A penetration test was conducted against the Mediroza General Hospital website to identify and exploit vulnerabilities to demonstrate their impact. The penetration test simulated an external attacker attempting to gain unauthorized access to systems through the website. A total of three security findings were identified during the assessment:

Severity	Total
Critical	1
High	2

The identified vulnerabilities primarily impact the confidentiality of the client's information. The highest-severity vulnerability allows an attacker to access an SQL backup file containing sensitive data of the hospitals' staff and shareholders. Overall, the security risk of the website is rated as High. It is recommended to fix the identified vulnerabilities and perform a retest to make sure that the vulnerabilities have been properly fixed.

02 Scope and Methodology

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Scope	Identify vulnerabilities, exploit them to demonstrate real impact, and document all findings in a professional report. Testing limited to the target domain only.
Out of Scope	Social engineering, denial of service, testing outside agreed scope.
Authorization	The client has provided written authorisation to conduct security testing on their web infrastructure.
Approach Type	Black-box Testing
Methodology	1. Reconnaissance 2. Initial Access 3. Exploitation 4. Post-Exploitation 5. Impact Assessment 6. Reporting
Tools Used	- Burp Suite - Networkwalks Hash Calculator - Networkwalks Password Cracker
Wordlists Used	- Networkwalks Built-in List - John the Ripper Default Password

03 Findings and Proof of Exploitation

A total of three findings identified during the penetration testing.

FINDING-M1: SQL Injection

Affected Resource	https://medirozahospital.com/patient/login.php
Severity	High

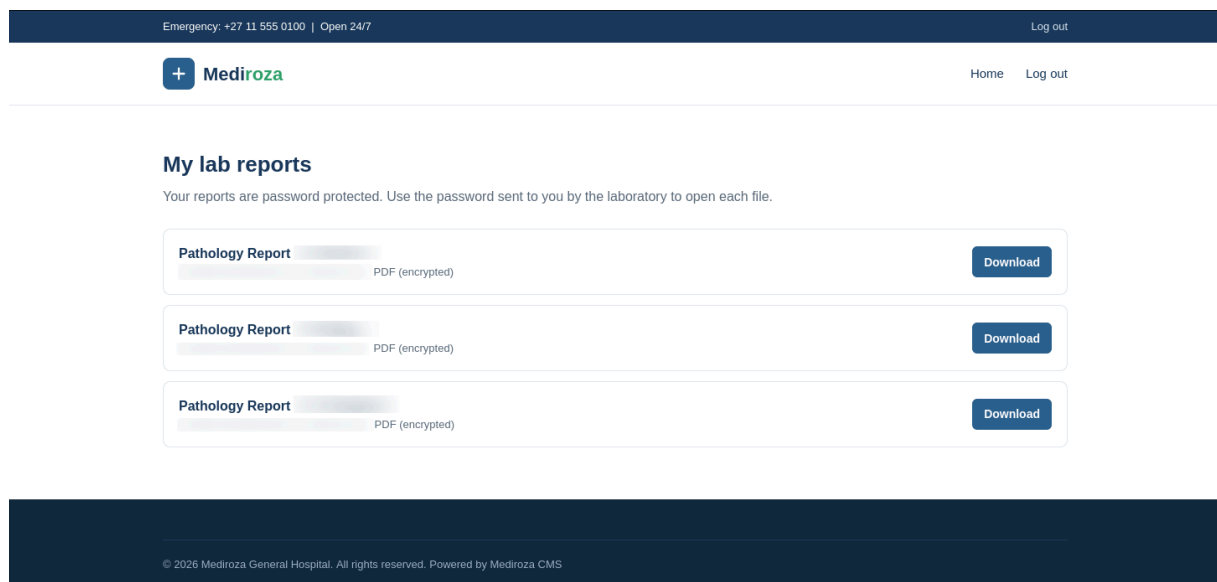
Description

The patient login page is vulnerable to SQL injection due to insufficient input validation on the `username` parameter. This allows an attacker to manipulate the SQL query and bypass the authentication mechanism.

Exploitation Steps

1. Identify SQL Injection in the `username` parameter.
2. Use Burp Suite Intruder with [SQL Injection Auth Bypass Payloads](#) as the wordlist to identify a valid username.
3. A valid username identified.
4. Use the identified username to log in.
5. Successfully gain authenticated access.

Evidence



Evidence FINDING-M1: Authentication Bypassed using SQL Injection

Impact

An attacker can bypass the website's authentication mechanism and gain unauthorized access to download patient laboratory reports without knowing the valid credentials.

FINDING-M2: Weak Password Protection

Affected Resource	patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf
Severity	High

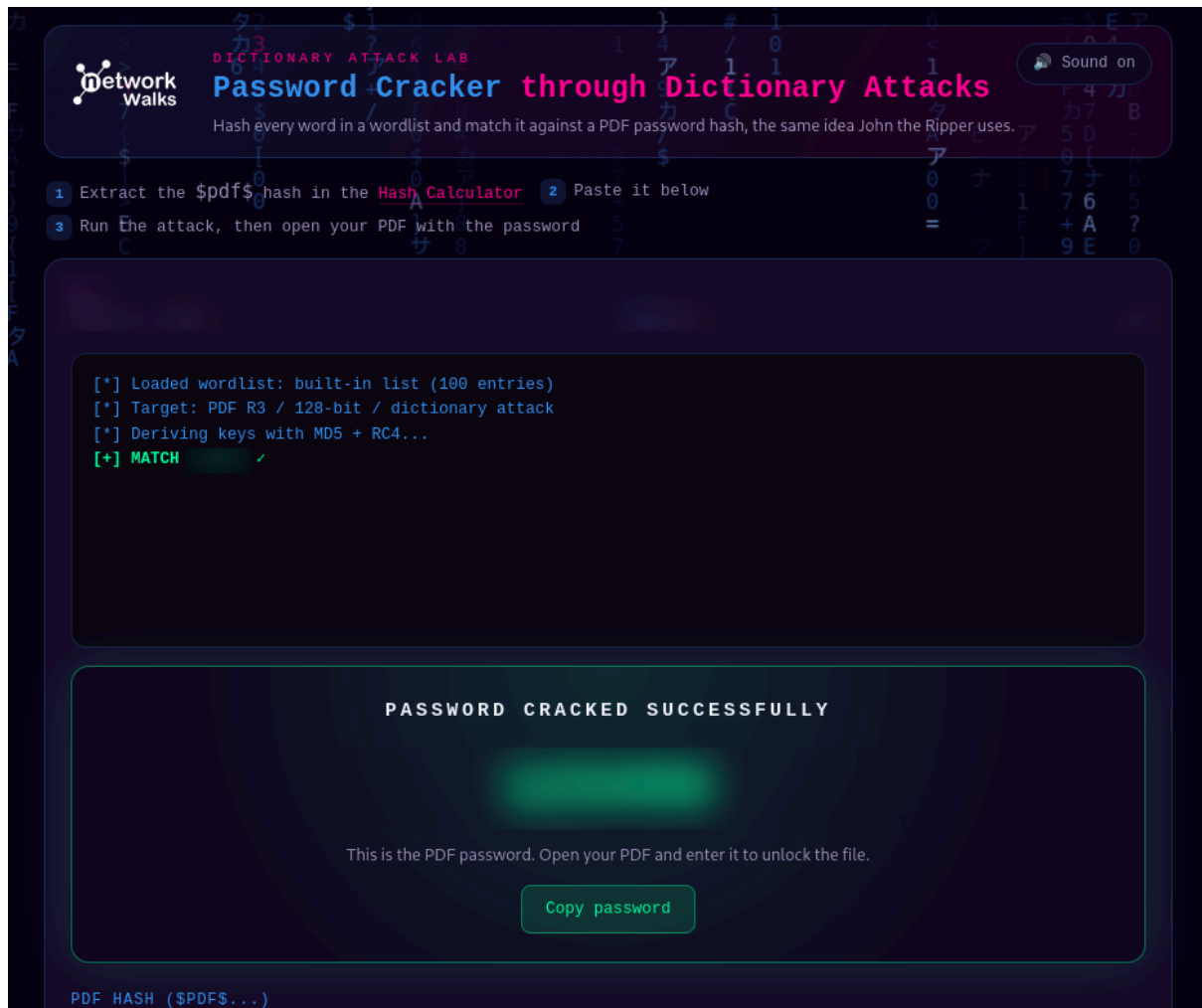
Description

The three PDF files obtained after login are password-protected. However, the weak password protection allows an attacker to recover the PDF passwords using password-cracking tools and publicly available wordlists.

Exploitation Steps

1. Download the PDFs.
2. Visit <https://networkwalks.com/hash-calculator/>, then upload the PDF.
3. Copy the hash value.
4. Visit <https://networkwalks.com/password-cracker>.
5. Paste the PDF hash value.
*for the 3rd PDF, use the john.lst wordlist located in /usr/share/wordlists/.
Change the file extension to .txt, then click **Upload Wordlist** and upload the john.txt.
Click on **Start Cracking**.
6. Copy the password.
7. Enter the obtained passwords in the protected PDFs.

Evidence



Evidence FINDING-M2.1a: Patient 1 Pathology Report PDF Password Cracked Successfully

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL



TEST	
Haemoglobin	
White Cell Count	
Platelet Count	
Fasting Glucose	
Creatinine	

Reported by

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

Evidence FINDING-M2.1b: Content of Patient 1 Pathology Report PDF

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL



TEST	
Total Cholesterol	
LDL Cholesterol	
HDL Cholesterol	
Triglycerides	
Fasting Glucose	

Reported by

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

Evidence FINDING-M2.2b: Content of Patient 2 Pathology Report PDF

 **DICTIONARY ATTACK LAB**

Password Cracker through Dictionary Attacks

Hash every word in a wordlist and match it against a PDF password hash, the same idea John the Ripper uses.

1 Extract the \$pdf\$ hash in the [Hash Calculator](#)

2 Paste it below

3 Run the attack, then open your PDF with the password

```
[+] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[-] Trying: x
[+] MATCH ✓
```

PASSWORD CRACKED SUCCESSFULLY

This is the PDF password. Open your PDF and enter it to unlock the file.

[Copy password](#)

PDF HASH (\$PDF\$...)

Evidence FINDING-M2.3a: Patient 3 Pathology Report PDF Password Cracked

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

			
TEST			
Haemoglobin			
Ferritin			
TSH			
Vitamin D			
Fasting Glucose			

Reported by

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

Evidence FINDING-M2.3b: Content of Patient 3 Pathology Report PDF

Impact

An attacker can access patients' pathology reports, resulting in unauthorized disclosure of sensitive patient information.

FINDING-M3: Sensitive Data Exposure

Affected Resource	https://medirozahospital.com/old/mediroza_db_backup_2019.sql
Severity	Critical

Description

The publicly accessible `robots.txt` file discloses the `/old/` path, which contains an SQL database backup file containing sensitive information about the hospital's staff and shareholders.

Exploitation Steps

1. Navigate to <https://medirozahospital.com/robots.txt>.
2. The `robots.txt` file is publicly accessible and discloses several paths, including `/patient/`, `/staff/`, and `/old/`.
3. Navigate to the `/old/` path.
4. An SQL database backup file is publicly accessible under this directory.
5. The exposed SQL backup contains sensitive information.

Evidence

```
LOCK TABLES `staff` WRITE;
INSERT INTO `staff`
(`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`)
VALUES
```

Evidence FINDING-M3.1: Staff Table

```
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder name`,`share percent`,`shares held`,`share class`) VALUES
```

Evidence FINDING-M3.2: Shareholders Table

Sample of Staff Table from the exposed SQL database backup file

No	Full Name	Job Title	Department	Monthly Salary (ZAR)
1	*****	*****	Diagnostics Lab	***,000
2	*****	*****	Finance	** ,000
3	*****	*****	Management	** ,000
4	*****	*****	Cardiology	***,000
5	*****	*****	Internal Medicine	** ,000

Sample of Shareholders Table from the exposed SQL database backup file

No	Shareholder Name	Share Percent	Shares Held	Share Class
1	*****	**	** ,000	Oddinary
2	*****	**	** ,000	Oddinary
3	*****	**	** ,000	Oddinary
4	*****	*	** ,000	Oddinary
5	*****	*	** ,000	Oddinary

Impact

An attacker can access and extract sensitive data of the hospital's staff and shareholders from the exposed SQL back up file without authorization. The file contains the following informations:

Table	Sensitive Information Exposed
Staff	Full name, job title, department, email, phone, national id, monthly salary, date joined
Shareholders	Shareholder name, share percent, shares held, share class

Unauthorized disclosure of this information could lead to privacy violations, targeted phishing or social engineering attacks, and potential reputational or regulatory consequences for the hospital.

04 Risk Rating

No	Finding	Severity	Justification
1	FINDING-M1: SQL Injection	High	An attacker can bypass authentication and gain unauthorized access to download patient lab reports without valid credentials. The compromised account doesn't provide functionality to create, update, upload, or delete patient records.
2	FINDING-M2: Weak Password Protection	High	An attacker can recover the PDF passwords and access confidential patient pathology reports.
3	FINDING-M3: Sensitive Data Exposure	Critical	An attacker can access sensitive information belonging to the hospital's staff and shareholders. The exposed information includes highly sensitive data such as national ID numbers, salary information, and personal contact information.

05 Recommendations and Remediation

No	Finding	Recommendations and Remediation
1	FINDING-M1: SQL Injection	1. Implement prepared statements with variable binding (parameterized queries) for the username parameter to ensure that user-supplied input is treated as data rather than executable SQL syntax. 2. Review the login functionality to ensure that authentication cannot be bypassed through manipulated input.
2	FINDING-M2: Weak Password Protection	1. Use a password that is at least 15 characters long. A passphrase can help you come up with something long and memorable. 2. Avoid using predictable or commonly used passwords.
3	FINDING-M3: Sensitive Data Exposure	1. Remove the SQL database backup from the web-accessible directory. 2. Restrict public access to the directories. 3. Ensure that sensitive backup files cannot be accessed directly through the web server.